

Kristi Talving
Tarbijakaitse ja Tehnilise Järelevalve Amet
Endla 10A, 10122 Tallinn, Harju maakond
info@ttja.ee

MÄRGUKIRI

08.04.2026

Lugupeetud peadirektor

Käesolevaga edastan Tarbijakaitse ja Tehnilise Järelevalve Ametile märgukirja seoses mitmete Eesti e-teenuse pakkujate poolt Smart-ID autentimisteenuse turundamisega tarbijatele. Kättesaadav tehniline dokumentatsioon ning sõltumatud tehnilised analüüsid viitavad sellele, et mitmete e-teenuste pakkujate tegevus võib olla vastuolus tarbijakaitseaduses sätestatud nõuetega.

1. Asjaolud ja taust

SK ID Solutions AS pakub Smart-ID teenust, mis on Eesti digitaalse infrastruktuuri oluline osa. Smart-ID teenust turundatakse tarbijatele kui maksimaalselt turvalist ja eIDAS määruse kohaselt kõrgeima usaldusväarsuse tasemega autentimis- ja allkirjastamisvahendit.

SK ID Solutions AS-i avaldatud e-teenuse pakkujatele suunatud liidese (Smart-ID RP API v3, docs.smart-id.com) dokumentatsioonist selgub, et teenus pakub mitut autentimisvoogu, millel on erinev turvalisuse tase:

1.1. Kontrollkoodi valikuvoog (Verification Code Choice, VC flow): Dokumentatsioonis on see märgitud kui soovitatav ja turvalisem lahendus. Kasutatakse seadmeline (QR-koodi skaneerimine või rakendusevaheline link), mis pakub maksimaalset kaitset õngitsusrünnete vastu.

1.2. Teavitusepõhine autentimisvoog (notification-based flow): Dokumentatsioonis on see märgitud kui „Not Recommended“ (mitte soovitatav). SK ID Solutions AS möönab dokumentatsioonis otse: „Phishing protection relies on user awareness“ — see tähendab, et kaitse õngitsusrünnete vastu tugineb üksnes kasutaja teadlikkusel.

Lisa 2:s on loetletud konkreetsete Eesti e-teenuse pakkujad, kes kasutavad teavitusepõhist autentimisvoogu ja turundavad oma teenuseid Smart-ID abil sisselogimist võimaldades turvalisena, kuigi nad ei rakenda kontrollkoodi valikuvoogu. Need ettevõtted varjavad tarbijalt teavet selle kohta, et kasutatav meetod ei paku maksimaalset kaitset.

Võrdlusena on Põhjamaade BankID läbinud sarnase kriisi, kus finantsjärelevalve ja küberkaitseasutuste survele oldi sunnitud turvalisemate voogude kasutuselevõtuks. See näitab, et sarnased regulatiivsed sekkumised on tõhusad meetodid turvalisuse standardite tõstmiseks digitaalse autentimise valdkonnas.

2. Õiguslik alus

Käesolev märgukiri keskendub üksnes Tarbijakaitseseaduses (TKS) sätestatud nõuete võimalikule rikkumisele, mille järelevalve TTJA pädevusse kuulub. Õiguslik alus tugineb TKS §-dele 15 ja 16 ning Euroopa Parlamendi ja nõukogu direktiivi 2005/29/EÜ (ebaausate kaubandustavade direktiiv) asjakohastele sätetele:

- Artikkel 5 — Ebaausate kaubandustavate üldine keeld ja professionaalse hoolikuse nõue (ametialane hoolsus)
- Artikkel 6 lg 1(a) — Eksitav tegevus, sh valeandmed kauba või teenuse peamiste omaduste kohta, sh kaasnevad riskid
- Artikkel 6 lg 2 — Muu hulgas loetakse toote omaduste hulka ka riskid, mis kaasnevad toote kasutamisega
- Artikkel 7 lg 2 — Eksitav tegevusetus, sh olulise teabe varjamine

Käesoleva märgukirja õiguslik analüüs põhineb Tarbijakaitseseadusel (RT I, 08.07.2025, 32) asjakohastel sätetel.

2.1. TKS § 15 — Ebaaus kauplemisvõte

TKS § 15 lg 1 kohaselt on kauplemisvõte ebaaus, kui see on vastuolus kaupleja majandus- või kutsetegevuses järgitava hoolsuse (kaupleja ametialane hoolsus) nõuetega ja seoses mõne kauba või teenusega moonutab või tõenäoliselt moonutab oluliselt selle keskmise tarbija majanduskäitumist, kes selle kauba või teenusega kokku puutub või kellele see on suunatud.

Käesoleval juhul võib e-teenuse pakkujate poolt teavitusepõhise autentimisvoo kasutamine koos teenuse turvalisena turundamisega kujutada endast kauplemisvõtet, mis ei vasta kaupleja ametialase hoolsuse nõuetele. SK ID Solutions AS on oma dokumentatsioonis selgelt märkinud, et teavitusepõhine voo on „Not Recommended” ja ei paku maksimaalset kaitset. E-teenuse pakkuja, kes valib selle voo ja turundab seejärel oma teenuseid Smart-ID abil turvalisena, käitub vastuolus kaupleja ametialase hoolsuse nõuetega — eriti arvestades, et tarbija ei saa ise seda otsust mõjutada.

Kauplemisvõte moonutab oluliselt keskmise tarbija majanduskäitumist, kui tarbija, kes usaldab Smart-ID logo kui maksimaalse turvalisuse sümbolit, ei saa teavet selle kohta, et konkreetne teenus kasutab madalama turvalisusega voogu. See võib viia tarbija otsuseni kasutada teenust arvates, et see pakub kõrgemat turvalisust, kui see tegelikult pakub. Arvestades, et Smart-ID-d kasutatakse pangandustoiminguteks, riigi teenustesse sisselogimiseks ja õiguslikku siduvate dokumentide allkirjastamiseks, on sellise moonutuse mõju majanduskäitumisele oluline.

2.2. TKS § 16 — Eksitav kauplemisvõte

TKS § 16 lg 1 kohaselt on eksitav kauplemisvõte nii eksitav tegevus kui ka tegevusetus.

TKS § 16 lg 2 kohaselt peetakse kauplemisvõtet eksitavaks, kui sellega esitatud teave on ebaõige või kui faktiliselt õige teabe esitusviis petab või tõenäoliselt petab keskmist tarbijat ja kummalgi juhul teeb või tõenäoliselt teeb keskmine tarbija selle mõjul tehinguotsuse, mida ta muul juhul ei oleks teinud. Ebaõige teave sisaldab muu hulgas valeandmeid kauba või teenuse peamiste omaduste kohta.

TKS § 16 lg 3 kohaselt peetakse eksitavaks kauplemisvõtet ka siis, kui see jätab keskmise tarbija

teadmatuseks olulise teabe, mida ta vajab teadliku majanduskäitumise otsuse tegemiseks, ja kui see petmise tõttu aitab kaasa otsusele osta kaupa või teenust.

TKS § 16 lg 6 kohaselt peetakse eksitavaks kauplemisvõtet ka siis, kui selle mõjul teeb või tõenäoliselt teeb keskmine tarbija tehinguotsuse, mida ta muul juhul ei oleks teinud, ja kui sellest konkreetses olukorras ei selgu oluline teave, mida keskmine tarbija vajab teadliku tehinguotsuse tegemiseks, või kui sellega on varjatud olulist teavet.

Direktiivi 2005/29/EÜ artikli 6 lg 2 kohaselt kuuluvad toote peamiste omaduste hulka muu hulgas tootega kaasnevad riskid. Direktiivi artikli 7 lg 2 kohaselt loetakse eksitavaks tegevusetuseks samuti seda, kui ettevõtja varjab olulist teavet või esitab seda ebaselgelt, arusaamatult, mitmetähenduslikult või ebaõigel ajal.

Käesoleval juhul esineb eksitava kauplemistava aspekt seoses tegevusetusega:

E-teenuse pakkuja, kes kasutab teavitusepõhist autentimisvoogu ja lubab Smart-ID abil sisselogimist, esitab tarbijale Smart-ID logo, mis kannab endaga eeldust maksimaalsest turvalisusest. Keskmine tarbija, kes näeb Smart-ID-d, eeldab eIDAS määruse kohast kõrgeimat turvalisuse taset, arvestades teenuse positsiooni Eesti digitaalses infrastruktuuris.

TKS § 16 lg 3 ja direktiivi artikli 6 lg 2 kohaselt kuuluvad teenuse peamiste omaduste hulka kaasnevad riskid. Tarbija peab saama teavet teenuse kasutamisega kaasnevate riskide kohta enne tehinguotsuse tegemist. Käesoleval juhul on oluline teave järgmine:

- Kasutatav Smart-ID autentimisvoog ei paku maksimaalset kaitset õngitsus- ja MFA-kurnamisrünnete vastu;
- Tarbija ei saa ise valida turvalisemat autentimisviisi, kuna see otsus kuulub e-teenuse pakkujaile;
- E-teenuse pakkuja ei ole tarbijat sellest erinevusest teavitanud.

See teabe varjamine võib tuua kaasa tarbija eksitava mulje teenuse tegelikust turvalisuse tasemest. Kui keskmine tarbija oleks teadlik, et konkreetne e-teenuse pakkuja kasutab madalama turvalisusega voogu, võiks ta otsustada kas kasutada teenust koos suurema ettevaatusega, valida alternatiivne autentimisviis (kui see on saadaval) või loobuda teenuse kasutamisest. Kuna tarbija ei saa seda teavet, teeb ta tehinguotsuse, mida ta muul juhul ei oleks teinud — see on TKS § 16 lg 6 ja direktiivi artikli 7 lg 2 mõttes eksitav tegevusetus.

Märkus „tehinguotsuse“ laiendatud tõlgendamisest: Euroopa Kohtu praktika kohaselt (nt kohtuasi C-281/12, Trento Sviluppo) hõlmab „tehinguotsus“ tarbijaõiguste direktiivi mõttes ka tarbija otsust kasutada lepingust tulenevaid õigusi, sh sisselogimist iseteenindusse kontole juurdepääsemiseks, arvete tasumiseks või lepingutingimuste muutmiseks. Seega ei ole oluline, kas tarbija sõlmib sisselogimise käigus uue lepingu — juba asjaolu, et tarbija kasutab olemasoleva teenuse iseteenindust, kujutab endast kaitset väärivat tehinguotsust TKS § 16 lg 2 ja lg 6 mõttes.

3. Taotlus asutusele

MFA-kurnamisründed (MFA fatigue / push bombing attacks) on Eestis reaalne ja sagenev küberoht, mis on viinud tarbijate reaalsele finantskahjudeni. SK ID Solutions AS-i enda dokumentatsioon tunnistab, et teavitusepõhine voog, kus kaitse „tugineb kasutaja teadlikkusele“, ei paku kaasaegset kaitset selliste rünnete vastu. Seetõttu on käesolev märgukiri esitatud avalikes huvides, et kaitsta tarbijaid teadmatusest tuleneva ebaausa kauplemistava eest.

Tuginedes eeltoodule, palun Tarbijakaitse ja Tehnilise Järelevalve Ametil:

3.1. Hinnata, kas e-teenuse pakkujate (nagu on loetletud Lisa 2-s) poolt teavitusepõhise Smart-ID autentimisvoo kasutamine koos teenuse Smart-ID abil turvalisena turundamisega vastab TKS § 15 lg 1 nõuetele kaupleja ametialase hoolsuse osas, arvestades et nimetatud e-teenuse pakkuja valik mitte kasutada kontrollkoodi valikuvoogu on vastuolus SK ID Solutions AS-i dokumentatsioonis sätestatud soovituselga.

3.2. Hinnata, kas TKS § 16 lg 6 kohane teabekohustus nõuab, et e-teenuse pakkuja oleks kohustatud tarbijat teavitama kasutatavast Smart-ID autentimisvoost ja selle turvalisuse tasemest enne teenuse kasutamist, arvestades et tarbija ei saa ise autentimisvoogu valida.

3.3. Kaaluda menetluse alustamist TKS § 15 ja § 16 alusel, et tuvastada, kas e-teenuse pakkujad, kes kasutavad teavitusepõhist Smart-ID autentimisvoogu ja turundavad teenust turvalisena, on rikkunud eksitava kauplemistava keeldu.

3.4. Kaaluda suuniste avaldamist selle kohta, milline teave peab olema tarbijatele kättesaadav Smart-ID autentimisvoo valiku kohta, sealhulgas kas e-teenuse pakkujad on kohustatud tarbijat teavitama, kui nad ei kasuta kontrollkoodi valikuvoogu.

4. Märkused käesoleva märgukirja ulatuse kohta

Käesolev märgukiri keskendub üksnes tarbijakaitse seaduse alusel TTJA pädevusse kuuluvatele küsimustele. Tuginen, et SK ID Solutions AS-i tehnilise arhitektuuri ja selle vastavusele eIDAS määruse nõuetele (sh usaldusteenuse osutaja kohustustele) kohaldub Riigi Infosüsteemi Ameti (RIA) pädevus. Samuti võivad antud küsimused puudutada isikuandmete kaitse üldmääruse (GDPR) nõudeid, mille järelevalve pädevus kuulub Andmekaitse Inspeksioonile.

Märkus RIA eksperthinnangu kohta: Käesolev märgukiri ei sea kahtluse alla teavitusepõhise autentimisvoo vastavust miinimumturvanõuetele. Isegi juhul, kui RIA kinnitab, et teavitusepõhine voog vastab õiguslikele miinimumstandarditele, jääb käesolev kaebus põhjatuks, kuna see keskendub turunduskommunikatsiooni ja tegeliku teenuse taseme erinevusele. E-teenuse pakkuja, kes turundab Smart-ID-d kui „maksimaalselt turvalist“ lahendust, kuid kasutab tegelikkuses „Not Recommended“ voogu, eksitab tarbijat turunduskommunikatsiooniga — see on TKS § 16 lg 6 ja direktiivi 2005/29/EÜ artikli 7 lg 2 mõttes eksitav tegevusetus, mis ei sõltu sellest, kas miinimumstandard on täidetud.

Käesolevaga kinnitan valmisolekut pakkuda vajadusel täiendavaid tehnilisi selgitusi.

Palun vastata mulle kirjalikult e-postiga.

Lugupidamisega

(allkirjastatud digitaalselt)

Tom Kristian Abel
Märgukirja esitaja

Tom Kristian Abel

Lisad:

Smart-ID RP API v3 dokumentatsiooni väljavõtted (autentimisvood ja nende turvalisuse tase — vt Lisa 1)

E-teenuse pakkujad, kes kasutavad teavitusepõhist autentimisvoogu (Lisa 2)